

1. Ethical hacker Jane Smith is attempting to perform an SQL Injection attack, she wants to test the response time of a true or fake response and wants to use a second command to determine whether the database will return true or false results for User 10%

Which two injection types would give her the results she is looking for?

time-based and boolean based

Union-based and error-based

Time-based and union-based

Out of band and boolean based

2. Andrew is an Ethical Hacker who was assigned the task of discovering all the active devices hidden by a restrictive firewall in the IPv4 range in a given target network.

Which of the following host discovery techniques must he use to perform the given task?

TCP Maimon scan

ARP ping scan

ACK flag probe scan

UDP scan

3. Jim, a professional hacker, targeted an organization that is operating critical industrial infrastructure. Jim used Nmap to scan open ports and running services on systems connected to the organization's OT network. He used an Nmap command to identify Ethernet/IP devices connected to the Internet and further gathered information such as the vendor name, product code and name, device name, and IP address.

Which of the following Nmap commands helped Jim retrieve the required information?

`nmap -Pn-sU-p 44818--script enip-info < Target IP >`

`nmap-Pn-sT --scan-delay 1s --max-parallelism 1 -p < Port List > < Target IP >`

`nmap-Pn-sT -p 46824 < Target IP >`

`nmap-Pn-sT -p 102 --script s7-info < Target IP >`

4. You are a penetration tester and are about to perform a scan on a specific server. The agreement that you signed with the client contains the following specific condition for the scan: "The attacker must scan every port on the server several times using a set of spoofed source IP addresses." Suppose that you are using Nmap to perform this scan. What flag will you use to satisfy this requirement?

The-A flag

The -f flag

The-g flag

The-D flag

5. Joel, a professional hacker, targeted a company and identified the types of websites frequently visited by its employees. Using this information, he searched for possible loopholes in these websites and injected a malicious script that can redirect users from the web page and download malware onto a victim's machine. Joel waits for the victim to access the infected web application so as to compromise the victim's machine. Which of the following techniques is used by Joel in the above scenario?

Watering hole attack

MarioNet attack

DNS rebinding attack

Clickjacking attack

6. Richard, an attacker, aimed to hack IoT devices connected to a target network. In this process, Richard recorded the frequency required to share information between connected devices. After obtaining the frequency, he captured the original data when commands were initiated by the connected devices. Once the original data were collected, he used free tools such as URH to segregate the command sequence. Subsequently, he started injecting the segregated command sequence on the same frequency into the IoT network, which repeats the captured signals of the devices.

What is the type of attack performed by Richard in the above scenario?

Side-channel attack

Replay attack

Reconnaissance attack

Cryptanalysis attack

7. Morris, a professional hacker, performed a vulnerability scan on a target organization by sniffing the traffic on the network to identify the active systems, network services, applications, and vulnerabilities. He also obtained the list of the users who are currently accessing the network. What is the type of vulnerability assessment that Morris performed on the target organization?

External assessment

Credentialed assessment

Internal assessment

Passive assessment

8. Abel, a security professional, conducts penetration testing in his client organization to check for any security loopholes. He launched an attack on the DHCP servers by broadcasting forged DHCP requests and leased all the DHCP addresses available in the DHCP scope until the server could not issue any more IP addresses. This led to a DoS attack, and as a result, legitimate employees were unable to access the client's network.

Which of the following attacks did Abel perform in the above scenario?

VLAN hopping

DHCP starvation

STP attack

Rogue DHCP server attack

9. Dorian is sending a digitally signed email to Polly. With which key is Dorian signing this message and how is Poly validating it?

Dorian is signing the message with his public key, and Poly will verify that the message came from Dorian by using Dorian's private key.

Dorian is signing the message with Poly's private key, and Poly will verify that the message came from Dorian by using Dorian's public key.

Dorian is signing the message with his private key, and Poly will verify that the message came from Dorian by using Dorian's public key.

Dorian is signing the message with Poly's public key, and Poly will verify that the message came from Dorian by using Dorian's public key.

10. Suppose that you test an application for the SQL injection vulnerability. You know that the backend database is based on Microsoft SQL Server. In the login/password form, you enter the following credentials:

Username: attack' or 1=1-

Password: 123456

Based on the above credentials, which of the following SQL commands are you expecting to be executed by the server, if there is indeed an SQL injection vulnerability?

select from Users where UserName = 'attack' or 1=1 and UserPassword = '123456'

select from Users where UserName = 'attack or 1=1 and UserPassword = '123456'

select from Users where UserName = 'attack" or 1=1 and UserPassword = '123456'

select from Users where UserName = 'attack' or 1=1 --' and UserPassword = '123456'

11. While performing an Nmap scan against a host, Paola determines the existence of a firewall. In an attempt to determine whether the firewall is stateful or stateless, which of the following options would be best to use?

-SA

-ST

-SX

-SF

12. Consider the following Nmap output:

Starting Nmap X.XX (<http://nmap.org>) at XXX-XX-XX XX:XX EDT

Nmap scan report for 192.168.1.42 Host is up (0.00023s latency).

Not shown: 932 filtered ports, 56 closed ports

PORT STATE SERVICE

21/tcp open ftp

22/tcp open ssh

25/tcp open smtp

53/tcp open domain

80/tcp open http

110/tcp open pop3

143/tcp open imap

443/tcp open https

465/tcp open smtps

587/tcp open submission

993/tcp open imaps

995/tcp open pop3s

Nmap done: 1 IP address (1 host up) scanned in 3.90 seconds

What command-line parameter could you use to determine the type and version number of the web server?

-sS

-Pn

-sV

-V

13. In this form of encryption algorithm, every individual block contains 64-bit data, and three keys are used, where each key consists of 56 bits. Which is this encryption algorithm?

AES

MD5 encryption algorithm

Triple Data Encryption Standard

IDEA

14. Tony is a penetration tester tasked with performing a penetration test. After gaining initial access to a target system, he finds a list of hashed passwords.

Which of the following tools would not be useful for cracking the hashed passwords?

netcat

THC-Hydra

Hashcat

John the Ripper

15. Wilson, a professional hacker, targets an organization for financial benefit and plans to compromise its systems by sending malicious emails. For this purpose, he uses a tool to track the emails of the target and extracts information such as sender identities, mail servers, sender IP addresses, and sender locations from different public sources. He also checks if an email address was leaked using the haveibeenpwned.com API.

Which of the following tools is used by Wilson in the above scenario?

Netcraft

Factiva

Zoominfo

Infoga

16. Joe works as an IT administrator in an organization and has recently set up a cloud computing service for the organization. To implement this service, he reached out to a telecom company for providing Internet connectivity and transport services between the organization and the cloud service provider.

In the NIST cloud deployment reference architecture, under which category does the telecom company fall in the above scenario?

Cloud broker

Cloud auditor

Cloud consumer

Cloud carrier

17. Emily, an extrovert obsessed with social media, posts a large amount of private information, photographs, and location tags of recently visited places. Realizing this, James, a professional hacker, targets Emily and her acquaintances, conducts a location search to detect their geolocation by using an automated tool, and gathers information to perform other sophisticated attacks.

What is the tool employed by James in the above scenario?

VisualRoute

ophcrack

HULK

Hootsuite

18. Stella, a professional hacker, performs an attack on web services by exploiting a vulnerability that provides additional routing information in the SOAP header to support asynchronous communication. This further allows the transmission of web-service requests and response messages using different TCP connections.

Which of the following attack techniques is used by Stella to compromise the web services?

Web services parsing attacks

SOAPAction spoofing

WS-Address spoofing

XML injection

19. Alice, a professional hacker, targeted an organization's cloud services. She infiltrated the target's MSP provider by sending spear-phishing emails and distributed custom-made malware to compromise user accounts and gain remote access to the cloud service. Further, she accessed the target customer profiles with her MSP account, compressed the customer data, and stored them in the MSP. Then, she used this information to launch further attacks on the target organization.

Which of the following cloud attacks did Alice perform in the above scenario?

Man-in-the-cloud (MITC) attack

Cloud cryptojacking

Cloud hopper attack

Cloudborne attack

20. In the Common Vulnerability Scoring System (CVSS) v3.1 severity ratings, what range does medium vulnerability fall in?

4.0-6.9

3.0-6.9

4.0-6.0

3.9-6.9

21. Ricardo has discovered the username for an application in his target's environment. As he has a limited amount of time, he decides to attempt to use a list of common passwords he found on the Internet. He compiles them into a list and then feeds that list as an argument into his password-cracking application.

What type of attack is Ricardo performing?

Dictionary

Known plaintext

Password spraying

Brute force

22. John, a professional hacker, performs a network attack on a renowned organization and gains unauthorized access to the target network. He remains in the network without being detected for a long time and obtains sensitive information without sabotaging the organization.

Which of the following attack techniques is used by John?

Advanced persistent threat

Diversion theft

Spear-phishing sites

Insider threat

23. By performing a penetration test, you gained access under a user account. During the test, you established a connection with your own machine via the SMB service and occasionally entered your login and password in plaintext.

Which file do you have to clean to clear the password?

profile

xsession-log

bashrc

bash_history

24. An organization decided to harden its security against web-application and web-server attacks. John, a security personnel in the organization, employed a security scanner to automate web-application security testing and to guard the organization's web infrastructure against web-application threats. Using that tool, he also wants to detect XSS, directory transversal problems, fault injection, SQL injection, attempts to execute commands, and several other attacks.

Which of the following security scanners will help John perform the above task?

Saleae Logic Analyzer

AlienVault® OSSIM™

Cisco ASA

Syhunt Hybrid

25. SQL injection (SQLi) attacks attempt to inject SQL syntax into web requests, which may bypass authentication and allow attackers to access and/or modify data attached to a web application.

Which of the following SQLi types leverages a database server's ability to make DNS requests to pass data to an attacker?

Union-based SQLi

Out-of-band SQLi

Time-based blind SQLi

In-band SQLi

26. Which iOS jailbreaking technique patches the kernel during the device boot so that it becomes jailbroken after each successive reboot?

Semi-tethered Jailbreaking

Untethered jailbreaking

Semi-untethered Jailbreaking

Tethered jailbreaking

27. There have been concerns in your network that the wireless network component is not sufficiently secure. You perform a vulnerability scan of the wireless network and find that it is using an old encryption protocol that was designed to mimic wired encryption. What encryption protocol is being used?

RADIUS

WEP

WPA3

WPA

28. Bob, an attacker, has managed to access a target IoT device. He employed an online tool to gather information related to the model of the IoT device and the certifications granted to it.

Which of the following tools did Bob employ to gather the above information?

Google image search

search.com

FCC ID search

Earth Explorer

29. Mike, a security engineer, was recently hired by BigFox Ltd. The company recently experienced disastrous DoS attacks. The management had instructed Mike to build defensive strategies for the company's IT infrastructure to thwart DoS/DDoS attacks. Mike deployed some countermeasures to handle jamming and scrambling attacks. What is the countermeasure Mike applied to defend against jamming and scrambling attacks?

Implement cognitive radios in the physical layer

Disable TCP SYN cookie protection

Allow the usage of functions such as gets and strcpy

Allow the transmission of all types of addressed packets at the ISP level

30. Becky has been hired by a client from Dubai to perform a penetration test against one of their remote offices. Working from her location in Columbus, Ohio, Becky runs her usual reconnaissance scans to obtain basic information about their network. When analyzing the results of her Whois search, Becky notices that the IP was allocated to a location in Le Havre, France. Which regional Internet registry should Becky go to for detailed information?

ARIN

APNIC

RIPE

LACNIC

31. An attacker utilizes a Wi-Fi Pineapple to run an access point with a legitimate-looking SSID for a nearby business in order to capture the wireless password. What kind of attack is this?

Phishing attack

Evil-twin attack

MAC spoofing attack

War driving attack

32. Taylor, a security professional, uses a tool to monitor her company's website, analyze the website's traffic, and track the geographical location of the users visiting the company's website.

Which of the following tools did Taylor employ in the above scenario?

Webroot

WebSite-Watcher

Web-Stat

WAFWOOF

33. There are multiple cloud deployment options depending on how isolated a customer's resources are from those of other customers. Shared environments share the costs and allow each customer to enjoy lower operations expenses. One solution is for a customer to join with a group of users or organizations to share a cloud environment.

What is this cloud deployment option called?

Community

Private

Public

Hybrid

34. Susan, a software developer, wants her web API to update other applications with the latest information. For this purpose, she uses a user-defined HTTP callback or push APIs that are raised based on trigger events; when Invoked, this feature supplies data to other applications so that users can instantly receive real-time information.

Which of the following techniques is employed by Susan?

Webhooks

Web shells

SOAP API

REST API

35. Mary, a penetration tester, has found password hashes in a client system she managed to breach. She needs to use these passwords to continue with the test, but she does not have time to find the passwords that correspond to these hashes.

Which type of attack can she implement in order to continue?

LLMNR/NBT-NS poisoning

Internal monologue attack

Pass the ticket

Pass the hash

36. Hackers often raise the trust level of a phishing message by modeling the email to look similar to the internal email used by the target company. This includes using logos, formatting, and names of the target company. The phishing message will often use the name of the company CEO, President, or Managers. The time a hacker spends performing research to locate this information about a company is known as?

Investigation

Enumeration

Exploration

Reconnaissance

37. Widespread fraud at Enron, WorldCom, and Tyco led to the creation of a law that was designed to improve the accuracy and accountability of corporate disclosures. It covers accounting firms and third parties that provide financial services to some organizations and came into effect in 2002. This law is known by what acronym?

PCI DSS

FedRAMP

HIPAA

SOX

38. Samuel, a security administrator, is assessing the configuration of a web server. He noticed that the server permits SSLv2 connections, and the same private key certificate is used on a different server that allows SSLv2 connections. This vulnerability makes the web server vulnerable to attacks as the SSLv2 server can leak key information.

Which of the following attacks can be performed by exploiting the above vulnerability?

Side-channel attack

DROWN attack

Padding oracle attack

DUHK attack

39. Security administrator John Smith has noticed abnormal amounts of traffic coming from local computers at night. Upon reviewing, he finds that user data have been exfiltrated by an attacker. AV tools are unable to find any malicious software, and the IDS/IPS has not reported on any non-whitelisted programs.

What type of malware did the attacker use to bypass the company's application whitelisting?

File-less malware

Logic bomb malware

Zero-day malware

Phishing malware

40. What is the common name for a vulnerability disclosure program opened by companies in platforms such as HackerOne?

Vulnerability hunting program

White-hat hacking program

Bug bounty program

Ethical hacking program

41. This wireless security protocol allows 192-bit minimum-strength security protocols and cryptographic tools to protect sensitive data, such as GCMP-256, HMAC-SHA384, and ECDSA using a 384-bit elliptic curve. Which is this wireless security protocol?

WPA3-Enterprise

WPA3-Personal

WPA2-Personal

WPA2-Enterprise

42. After an audit, the auditors inform you that there is a critical finding that you must tackle immediately. You read the audit report, and the problem is the service running on port 389.

Which service is this and how can you tackle the problem?

The service is NTP, and you have to change it from UDP to TCP in order to encrypt it.

The findings do not require immediate actions and are only suggestions.

The service is LDAP, and you must change it to 636, which is LDAPS.

The service is SMTP, and you must change it to SMIME, which is an encrypted way to send emails.

43. Attacker Rony installed a rogue access point within an organization's perimeter and attempted to intrude into its internal network. Johnson, a security auditor, identified some unusual traffic in the internal network that is aimed at cracking the authentication mechanism. He immediately turned off the targeted network and tested for any weak and outdated security mechanisms that are open to attack.

What is the type of vulnerability assessment performed by Johnson in the above scenario?

Distributed assessment

Host-based assessment

Wireless network assessment

Application assessment

44. What is the port to block first in case you are suspicious that an IoT device has been compromised?

48101

22

80

443

45. When analyzing the IDS logs, the system administrator noticed an alert was logged when the external router was accessed from the administrator's Computer to update the router configuration.

What type of an alert is this?

False negative

True negative

False positive

True positive

46. Boney, a professional hacker, targets an organization for financial benefits. He performs an attack by sending his session ID using an MITM attack technique. Boney first obtains a valid session ID by logging into a service and later feeds the same session ID to the target employee. The session ID links the target employee to Boney's account page without disclosing any information to the victim. When the target employee clicks on the link, all the sensitive payment details entered in a form are linked to Boney's account.

What is the attack performed by Boney in the above scenario?

CRIME attack

Forbidden attack

Session fixation attack

Session donation attack

47. Johnson, an attacker, performed online research for the contact details of reputed cybersecurity firms. He found the contact number of sibertech.org and dialed the

number, claiming himself to represent a technical support team from a vendor. He warned that a specific server is about to be compromised and requested sibertech.org to follow the provided instructions. Consequently, he prompted the victim to execute unusual commands and install malicious files, which were then used to collect and pass critical information to Johnson's machine.

What is the social engineering technique Steve employed in the above scenario?

Elicitation

Diversion theft

Quid pro quo

Phishing

48. During the enumeration phase, Lawrence performs banner grabbing to obtain information such as OS details and versions of services running. The service that he enumerated runs directly on TCP port 445.

Which of the following services is enumerated by Lawrence in this scenario?

Network File System (NFS)

Remote procedure call (RPC)

Server Message Block (SMB)

Telnet

49. This form of encryption algorithm is a symmetric key block cipher that is characterized by a 128-bit block size, and its key size can be up to 256 bits. Which among the following is this encryption algorithm?

IDEA

Twofish encryption algorithm

Blowfish encryption algorithm

HMAC encryption algorithm

50. Attacker Steve targeted an organization's network with the aim of redirecting the company's web traffic to another malicious website. To achieve this goal, Steve performed DNS cache poisoning by exploiting the vulnerabilities in the DNS server software and modified the original IP address of the target website to that of a fake website.

What is the technique employed by Steve to gather information for identity theft?

Skimming

Pretexting

Pharming

Wardriving

51. Samuel, a security administrator, is assessing the configuration of a web server. He noticed that the server permits SSLv2 connections, and the same private key certificate is used on a different server that allows SSLv2 connections. This vulnerability makes the web server vulnerable to attacks as the SSLv2 server can leak key information.

Which of the following attacks can be performed by exploiting the above vulnerability?

Side-channel attack

DROWN attack

Padding oracle attack

DUHK attack

52. Bobby, an attacker, targeted a user and decided to hijack and intercept all their wireless communications. He installed a fake communication tower between two authentic endpoints to mislead the victim. Bobby used this virtual tower to interrupt the data transmission between the user and real tower, attempting to hijack an active session. Upon receiving the user's request, Bobby manipulated the traffic with the virtual tower and redirected the victim to a malicious website.

What is the attack performed by Bobby in the above scenario?

Wardriving

aLTEr attack

CCCCC Jamming signal attack

KRACK attack

53.This wireless security protocol allows 192-bit minimum-strength security protocols and cryptographic tools to protect sensitive data, such as GCMP-256, HMAC-SHA384, and ECDSA using a 384-bit elliptic curve.

Which is this wireless security protocol?

WPA3-Enterprise

WPA3-Personal

WPA2-Personal

WPA2-Enterprise

54.Garry is a network administrator in an organization. He uses SNMP to manage networked devices from a remote location. To manage nodes in the network, he uses MIB, which contains formal descriptions of all network objects managed by SNMP. He accesses the contents of MIB by using a web browser either by entering the IP address and Lseries.mib or by entering the DNS library name and Lseries.mib. He is currently retrieving information from an MIB that contains object types for workstations and server services.

Which of the following types of MIB is accessed by Garry in the above scenario?

WINS.MIB

LNMB2.MIB

MIB_II.MIB

DHCP.MIB

55. Gerard, a disgruntled ex-employee of Sunglass IT Solutions, targets this organization to perform sophisticated attacks and bring down its reputation in the market. To launch the attacks process, he performed DNS footprinting to gather information about DNS servers and to identify the hosts connected in the target network. He used an automated tool that can retrieve information about DNS zone data including DNS domain names, computer names, IP addresses, DNS records, and network Whois records. He further exploited this information to launch other sophisticated attacks.

What is the tool employed by Gerard in the above scenario?

Towelroot

ZANTI

Bluto

Knative

56. Daniel is a professional hacker who is attempting to perform an SQL injection attack on a target website, www.moviescope.com. During this process, he encountered an IDS that detects SQL injection attempts based on predefined signatures. To evade any comparison statement, he attempted placing characters such as "" or '1'='1' in any basic injection statement such as "or 1=1."

Identify the evasion technique used by Daniel in the above scenario.

Null byte

Variation

IP fragmentation

Char encoding

57. Juliet, a security researcher in an organization, was tasked with checking for the authenticity of images to be used in the organization's magazines. She used these images as a search query and tracked the original source and details of the images, which included photographs, profile pictures, and memes.

Which of the following footprinting techniques did Rachel use to finish her task?

Meta search engines

Advanced image search

Google advanced search

Reverse image search

58. Harry, a professional hacker, targets the IT infrastructure of an organization. After preparing for the attack, he attempts to enter the target network using techniques such as sending spear-phishing emails and exploiting vulnerabilities on publicly available servers. Using these techniques, he successfully deployed malware on the target system to establish an outbound connection.

What is the APT lifecycle phase that Harry is currently executing?

Preparation

Initial intrusion

Persistence

Cleanup

59. Eric, a cloud security engineer, implements a technique for securing the cloud resources used by his organization. This technique assumes by default that a user attempting to access the network is not an authentic entity and verifies every incoming connection before allowing access to the network. Using this technique, he also imposed conditions such that employees can access only the resources required for their role. What is the technique employed by Eric to secure cloud resources?

Zero trust network

Demilitarized zone

Serverless computing

Container technology

60. What are common files on a web server that can be misconfigured and provide useful information for a hacker such as verbose error messages?

idq.dll

administration.config

httpd.conf

php.ini

61. Your company was hired by a small healthcare provider to perform a technical assessment on the network.

What is the best approach for discovering vulnerabilities on a Windows-based computer?

Create a disk image of a clean Windows installation

Use a scan tool like Nessus

Use the built-in Windows Update tool

Check MITRE.org for the latest list of CVE findings

62. CyberTech Inc. recently experienced SQL injection attacks on its official website. The company appointed Bob, a security professional, to build and incorporate defensive strategies against such attacks. Bob adopted a practice whereby only a list of entities such as the data type, range, size, and value, which have been approved for secured access, is accepted. What is the defensive technique employed by Bob in the above scenario?

Enforce least privileges

Whitelist validation

Output encoding

Blacklist validation

63. Bella, a security professional working at an IT firm, finds that a security breach has occurred while transferring important files. Sensitive data, employee usernames, and passwords are shared in plaintext, paving the way for hackers to perform successful session hijacking. To address this situation, Bella implemented a protocol that sends data using encryption and digital certificates.

Which of the following protocols is used by Bella?

IP

FTPS

HTTPS

FTP

64. Kevin, a professional hacker, wants to penetrate CyberTech Inc.'s network. He employed a technique, using which he encoded packets with Unicode characters. The company's IDS cannot recognize the packets, but the target web server can decode them.

What is the technique used by Kevin to evade the IDS system?

Urgency flag

Obfuscating

Desynchronization

Session splicing

65. Techno Security Inc. recently hired John as a penetration tester. He was tasked with identifying open ports in the target network and determining whether the ports are online and any firewall rule sets are encountered. John decided to perform a TCP SYN ping scan on the target network.

Which of the following Nmap commands must John use to perform the TCP SYN ping scan?

nmap-sn-PO < target IP address >

nmap-sn-PP < target IP address >

nmap-sn-PA < target IP address >

nmap-sn-PS < target IP address >

66. Widespread fraud at Enron, WorldCom, and Tyco led to the creation of a law that was designed to improve the accuracy and accountability of corporate disclosures. It covers

accounting firms and third parties that provide financial services to some organizations and came into effect in 2002. This law is known by what acronym?

PCI DSS

FedRAMP

HIPAA

SOX

67. A newly joined employee, Janet, has been allocated an existing system used by a previous employee. Before issuing the system to Janet, it was assessed by Martin, the administrator. Martin found that there were possibilities of compromise through user directories, registries, and other system parameters. He also identified vulnerabilities such as native configuration tables, incorrect registry or file permissions, and software configuration errors.

What is the type of vulnerability assessment performed by Martin?

Distributed assessment

Credentialed assessment

Host-based assessment

Database assessment

68. Which of the following Bluetooth hacking techniques refers to the theft of information from a wireless device through Bluetooth?

Bluebugging

Bluejacking

Bluesmacking

Bluesnarfing

69. John wants to send Marie an email that includes sensitive information, and he does not trust the network that he is connected to. Marie gives him the idea of using PGP. What should John do to communicate correctly using this type of encryption?

Use his own public key to encrypt the message.

Use his own private key to encrypt the message.

Use Marie's private key to encrypt the message.

Use Marie's public key to encrypt the message.

70. Heather's company has decided to use a new customer relationship management tool. After performing the appropriate research, they decided to purchase a subscription to a cloud-hosted solution. The only administrative task that Heather will need to perform is the management of user accounts. The provider will take care of the hardware, operating system, and software administration including patching and monitoring.

Which of the following is this type of solution?

IaaS

SaaS

CaaS

PaaS

71. Jude, a pen tester working in Keiltech Ltd., performs sophisticated security testing on his company's network infrastructure to identify security loopholes. In this process, he started to circumvent the network protection tools and firewalls used in the company. He employed a technique that can create forged TCP sessions by carrying out multiple

SYN, ACK, and RST or FIN packets. Further, this process allowed Jude to execute DDoS attacks that can exhaust the network resources.

What is the attack technique used by Jude for finding loopholes in the above scenario?

Ping-of-death attack

Spoofed session flood attack

Peer-to-peer attack

UDP flood attack

72.Which of the following protocols can be used to secure an LDAP service against anonymous queries?

SSO

WPA

NTLM

RADIUS

73.Mason, a professional hacker, targets an organization and spreads Emotet malware through malicious script. After infecting the victim's device, Mason further used Emotet to spread the infection across local networks and beyond to compromise as many machines as possible. In this process, he used a tool, which is a self- extracting RAR file, to retrieve information related to network resources such as writable share drives. What is the tool employed by Mason in the above scenario?

NetPass.exe

Outlook scraper

WebBrowserPassView

Credential enumerator

74.Which of the following allows attackers to draw a map or outline the target organization's network infrastructure to know about the actual environment that they are going to hack.

Scanning networks

Malware analysis

Vulnerability analysis

Enumeration

75. Annie, a cloud security engineer, uses the Docker architecture to employ a client/server model in the application she is working on. She utilizes a component that can process API requests and handle various Docker objects, such as containers, volumes, images, and networks.

What is the component of the Docker architecture used by Annie in the above scenario?

Docker daemon

Docker client

Docker registries

Docker objects

Q. Judy created a forum. One day, she discovers that a user is posting strange images without writing comments. She immediately calls a security expert, who discovers that the following code is hidden behind those images:

```
<script>
```

```
Document.write('
```

```
</script>
```

What issue occurred for the users who clicked on the image?

The code is a virus that is attempting to gather the user's username and password.

The code injects a new cookie to the browser.

This php file silently executes the code and grabs the user's session cookie and session ID

The code redirects the user to another site

Q. John, a professional hacker, decided to use DNS to perform data exfiltration on a target network, in this process, he embedded malicious data into the DNS protocol packets that even DNSSEC cannot detect. Using this technique, John successfully

injected malware to bypass a firewall and maintained communication with the victim machine and C&C server.

What is the technique employed by John to bypass the firewall?

DNS enumeration

DNSSEC zone walking

DNS cache snooping

DNS tunneling method

Q. Bob was recently hired by a medical company after it experienced a major cyber security breach, Many patients are complaining that their personal medical records are fully exposed on the Internet and someone can find them with a simple Google search. Bob's boss is very worried because of regulations that protect those data

Which of the following regulations is mostly violated?

PII

HIPAA/PHI

PCI DSS

ISO 2002

Q. Robin, a professional hacker, targeted an organization's network to sniff all the traffic. During this process, Robin plugged in a rogue switch to an unused port in the LAN with a priority lower than any other switch in the network so that he could make it a root bridge that will later allow him to sniff all the traffic in the network

What is the attack performed by Robin in the above scenario?

ARP spoofing attack

DNS poisoning attack

VLAN hopping attack

STP attack

Q. Attacker Simon targeted the communication network of an organization and disabled the security controls of NetNTLMV) by modifying values of LMCompatibilityLevel, NTLMMinClientSec, RestrictSending NTLMTraffic. He then extracted all the non-network

logon tokens from all the active processes to masquerade as a legitimate user to launch further attacks.

What is the type of attack performed by Simon?

Dictionary attack

Combinator attack

Rainbow table attack

Internal monologue attack

Q. Scenario: Joe turns on his home computer to access personal online banking. When he enters the URL www.bank.com, the website is displayed, but it prompts him to re-enter his credentials as if he has never visited the site before. When he examines the website URL closer, he finds that the site's web address appears different. Secure and the web address appears different.

What type of attack he is experiencing?

ARP cache poisoning

DHCP spoofing

DoS attack

DNS hijacking

Q. Gilbert, a web developer, uses centralized web API to reduce complexity and increase the integrity of updating and changing data. For this purpose, he uses a web service that uses HTTP methods such as PUT, POST, GET, and DELETE and can improve the overall performance, visibility, scalability, reliability, and portability of an application.

What is the type of web-service API mentioned in the above scenario?

REST API

JSON-RPC

RESTful API

OSOAP API

Q. An organization automated the operation of critical infrastructure from a remote location, For this purpose, all the industrial control systems connected to the Internet. To empower the manufacturing process, ensure the reliability of industrial networks, and reduce downtime and service disruption, the organization decided to install an OT security tool that further protects against security Incidents such as cyber espionage, Zero-day attacks, and malware. Which of the following tools must the organization employ to protect its critical infrastructure?

Flowmon

Inteni Furzer

BalenaCloud

Robotium

Q. Henry is a cyber security specialist hired by BlackEye Cyber Security Solutions. He was tasked with discovering the operating system (OS) of a host. He used the Unicornscan tool to discover the OS of the target system. As a result, he obtained a TTL value, which indicates that the target system is running a Windows OS. Identify the TTL value Henry obtained, which indicates that the target OS is Windows.

64

138

128

255

Q. What piece of hardware on a computer's motherboard generates encryption keys and only releases a part of the key so that decrypting a disk on a new piece of hardware is not possible?

CPU

GPU

TPM

UEFI

Q. Jane, an ethical hacker, is testing a target organization's web server and website to identify security loopholes In this process, she copied the entire website and its content on a local drive to view the complete profile of the site's directory structure, file

structure, external links, images, web pages, and so on. This information helps Jane map the website's directories and gain valuable information.

What is the attack technique employed by Jane in the above scenario?

Website defacement

Website mirroring

Web cache poisoning

Session hijacking

Q. A DDoS attack is performed at layer 7 to take down web infrastructure, Partial HTTP request web infrastructure or applications. Upon receiving a partial request, the target servers opens multiple connections and keepo waiting for the requests to complete Which attack is being described here?

Desynchronization

Polashing

Sawan suicing

Slowloris attack

Q. Jason, an attacker, targeted an organization to perform an attack on its internet facing web server with the intention of gaining access to backend servers, which are protected by a firewall. In this process, he used a URL <https://xyz.com/feed.php?uri=externalsite.com/feed/to> to obtain a remote feed and altered the URL input to the local host to view all the local resources on the target server.

What is the type of attack Jason performed in the above scenario?

Website defacement

Web server misconfiguration

Web cache poisoning attack

Server-side request forgery (SSRF) attack

Q. What would be the fastest way to perform content enumeration on a given web server by using the Gobuster tool?

Performing content enumeration using the bruteforce mode and 10 threads

Performing content enumeration using the bruteforce mode and random file extensions

Skipping SSL certificate verification

Performing content enumeration using a wordlist

Q. Jane invites her friends Alice and John over for a LAN party. Alice and John access Jane's wireless network without a password. However, Jane has a long, complex password on her router. What attack has likely occurred?

Piggybacking

Wardriving

Evil twin

Wireless sniffing

Q. Bill is a network administrator. He wants to eliminate unencrypted traffic inside his company's network. He captures all traffic to the datacenter. He immediately discovers unencrypted traffic and decides to setup a SPAN port for traffic on port UDP 161.

What protocol is this port using and how can he secure that traffic?

RPC and the best practice is to disable RPC completely

SNMP and he should change it to SNMP V3

It is not necessary to perform any actions, as SNMP is not carrying important information

SNMP and he should change it to SNMP V2, which is encrypted

Q. Sophia is a shopping enthusiast who spends significant time searching for trendy outfits online. Clark, an attacker, noticed her activities several times and sent a fake email containing a deceptive page link to her social media page displaying all-new and trendy outfits. In excitement, Sophia clicked on the malicious link and logged in to that page using her valid credentials.

Which of the following tools is employed by Clark to create the spoofed email?

Evilginx

Slowloris

PLCinject

PyLoris

Q. Which file is a rich target to discover the structure of a website during web-server footprinting?

Document root

Index.html

Domain.txt

Robots.txt

Q. Which of the following Metasploit post-exploitation modules can be used to escalate privileges on Windows

Keylogrecorder

Autoroute

Getsystem

Getuid

Q. You are attempting to run an Nmap port scan on a web server. Which of the following commands would result in a scan of common ports with the least amount of noise in order to evade IDS?

Nmap-ST -O -TO

Nmap-A--host-timeout 99-TI

Nmap-sp-p-65535-15

Nmap-A-Pn

Q. Sophia is a shopping enthusiast who spends significant time searching for trendy outfits online. Clark, an attacker, noticed her activities several times and sent a fake email containing a deceptive page link to her social media page displaying all-new and

trendy outfits. In excitement, Sophia clicked on the malicious link and logged in to that page using her valid credentials.

Which of the following tools is employed by Clark to create the spoofed email?

Evilginx

Slowloris

PLCinject

PyLoris

Q. While testing a web application in development, you notice that the web server does not properly ignore the “dot dot slash (../) character string and instead returns the file listing of a folder higher up in the folder structure of the server.

What kind of attack is possible in this scenario?

SQL injection

Directory traversal

Denial of service

Cross-site scripting

Q. George is a security professional working for iTech Solutions. He was tasked with securely transferring sensitive data of the organization between industrial systems, in this process, he used a short-range communication protocol based on the IEEE 203.15.4 standard. This protocol is used in devices that transfer data infrequently at a low rate in a restricted area, within a range of 10-100 m.

What is the short-range wireless communication technology George employed in the above scenario?

NB-IoT

Zigbee

MOTT

LPWAN

Q. David is organization, and he is implementing a vulnerability management program in the organization to evaluate and control the risks and vulnerabilities in its IT

Infrastructure. He is currently executing the process of applying fixes on vulnerable systems to reduce the impact and severity of vulnerabilities.

Which phase of the vulnerability-management life cycle is David currently in?

Vulnerability scan

Risk assessment

Verification

Remediation

Q. Alice needs to send confidential document to her coworker, Bryan. Their company has public key to infrastructure set up. Therefore, Alice both encrypts the message and digitally signs it. Alice uses encrypt the message, and Bryan uses to confirm the digital signature.

Bryan's public key, Bryan's public key

Bryan's private key, Alice's public key

Bryan's public key, Alice's public key

Alice's public key, Alice's public key

Q. in this attack, an adversary tricks victim into reinstalling an already in use key. This is achieved by manipulating and replaying cryptographic handshake messages. When the victim reinstalls the key associated parameters such as the incremental transmit packet number and receive packet number Initial values. What is this attack called?

Reset to their

Exill bwin

Chop chop attack

Wardriving

KRACK

Q. You are a penetration tester tasked with testing the wireless network of your client Brakeme SA. You are attempting to break into the wireless network with the SSID "Brakeme-Internal." You realize that this network uses WPA3 encryption.

Which of the following vulnerabilities is the promising to exploit?

Key reinstallation attack

Cross-site request forgery

Dragonblood

AP misconfiguration

Q. Sohn, professional hacker, targeted an organization that uses LDAP for accessing distributed directory services. He used an automated tool to anonymously query the LDAP service for sensitive information such usernames, addresses, departmental details, and server names organization launch further attacks on the target

What tool employed by John to gather information from the LDAP service?

Scan

Zabesearch

Jxplorer

EarthExplorer

Q. An organization is performing a vulnerability assessment for mitigating threats. James, a pen tester, scanned the organization by building an inventory of the protocols found on the organization's machines to detect which ports attached to services such an email server, a web server, or a database server. After Identifying the services, he selected the vulnerabilities on each machine and started executing only the relevant tests.

What is the type of vulnerability assessment solution that James employed in the above scenario?

Interference-based assessment

Product-based solutions

Service-based solutions

Tree-based assessment

Q. Don, a student, came across a gaming app in a third-party app store and installed it. Subsequently legitimate apps in his smartphone replaced by deceptive applications that appeared legitimate. He also received many advertisements on his smartphone after installing the app.

What is the attack performed on Don in the above scenario?

Clickjacking

Agent Smith attack

SIM card attack

SMS phishing attack

Q. Steve, an attacker, created a fake profile on a social media website and sent a request to Stella. Stella was enthralled by Steve's profile picture and the description given for his profile, and she initiated a conversation with him soon after accepting the request. After a few days, Steve started asking about her company details and eventually gathered all the essential information regarding her company.

What is the social engineering technique Steve employed in the above scenario?

Piggybacking

Honey trap

Baiting

Diversion theft

Q. Clark is a professional hacker. He created and configured multiple domains pointing to the quickly between the domains and avoid detection. Host to switch

Identify the behavior of the adversary in the above scenario.

Unspecified proxy activities

Use of DNS tunneling

Use of command line interface

Data staging

Q. Which of the following commands checks for valid users SMTP server?

RCPT

CHK

VRFY

EXPN

Q. An organization is performing a vulnerability assessment for mitigating threats. James, a pen tester, scanned the organization by building an inventory of the protocols found on the organization's machines to detect attached to services such as an email server, a web server, or a database server. After identifying the services, he selected the vulnerabilities on each machine and started executing only the which ports relevant tests

What type of vulnerability assessment solution that James employed in above scenario?

Interference-based assessment

Product-based solutions

Service-based solutions

Tree-based assessment

Q. Sam is a penetration tester hired by Inception Tech, a security organization. He was asked to perform port scanning on a target host in the network. While performing the given task, Sam sends FIN/ACK probes and determines that an RST packet is sent in response by the target host, indicating that the port is closed. What is the port scanning technique used by Sam to discover open ports?

IDLE/IPID header scan

ACK flag probe scan

Xmas scan

TCP Maimon scan

Q. Which of the following Google advanced search operators helps an attacker in gathering information about websites that are similar to a specified target URL?

[related:]

[site:]

[info:]

[inurl:]

Q. Clark, a professional hacker, was hired by an organization to gather sensitive information about its competitors surreptitiously, Clark gathers the server IP address of the target organization using Whois footprinting. Further. He entered the server IP address as an input to an online tool to retrieve information such as the network range of the target organization and to identify the network topology and operating system used in the network.

What is the online tool employed by Clark in the above scenario?

DuckDuckGo

Baidu

ARIN

AOL

Q. Allen, a professional pen tester, was hired by XpertTech Solutions to perform an attack simulation on the organization's network resources. To perform the attack, he took advantage of the NetBIOS API and targeted the NetBIOS service. By enumerating NetBIOS, he found that port 139 was open and could see the resources that could be accessed or viewed on a remote system. He came across many NetBIOS codes during enumeration.

Identify the NetBIOS code used for obtaining the messenger service running for the logged in user?

<1B>

<00>

<20>

<03>

Q. What firewall evasion scanning technique make use of a zombie system that has low network activity as well as its fragment identification numbers?

Packet fragmentation scanning

Spoof source address scanning

Idle scanning

Decoy scanning

Q. Jude, a pen tester, examined a network from a hacker's perspective to identify exploits and vulnerabilities accessible to the outside world by using devices such as firewalls, routers, and servers, in this process, he also estimated the threat of network security attacks and determined the level of security of the corporate network What is the type of vulnerability assessment that Jude performed on the organization?

Passive assessment

Application assessment

External assessment

Host-based assessment

Q. Nicolas just found a vulnerability on a public-facing system that is considered a zero-day vulnerability. He sent an email to the owner of the public system describing the problem and how the owner can protect themselves from that vulnerability. He also sent an email to Microsoft informing them of the problem that their systems are exposed to.

What type of hacker is Nicolas?

Black hat

White hat

Red hat

Gray hat

Q. At what stage of the cyber kill chain theory model does data exfiltration occur

Weaponization

Command and control

Actions on objectives

Installation

Q. What is the file that determines the basic configuration (specifically activities, services, broadcast receivers, etc.) in an Android application?

AndroidManifest.xml

Classesdex

APKInfo

Resources.asirC

Q. To create a botnet, the attacker can use several techniques to scan vulnerable machines. The attacker first collects information a large number of vulnerable machines to create a list. Subsequently, they infect the machines. The list is divided by assigning half of the list to the newly compromised machines. The scanning process runs simultaneously. This technique ensures the spreading and installation of malicious code in little time

Which technique is discussed here?

Subnet scanning technique

Permutation scanning technique

Hitlist scanning technique

Topological scanning technique

Q. While browsing his Facebook feed, Matt sees a picture one of his friends posted with the caption, “Learn more about your friends”, number of personal questions. Matt is suspicious and texts his friend, who confirms that he did indeed post it. With assurance that the post is legitimate, Matt responds to the questions on the post. A few days later, Matt’s bank account has been accessed, and the password has been changed. What most likely happened?

Matz inadvertently provided the answers to his security questions when responding to the post

Matz inadvertently provided his password when responding to the post

Matt’s bank account login information was brute forced.

Matt’s computer was infected with a keylogger.

Q. An organization has automated the operation of critical infrastructure from a remote location. For this purpose, all the industrial control systems are connected to the Internet. To empower the manufacturing process, ensure the reliability of industrial networks, and reduce downtime and service disruption, the organization decided to install an OT security tool that further protects against security incidents such as cyber espionage, zero-day attacks, and malware.

Which of the following tools must the organization employ to protect its critical infrastructure?

Flowmon

Intent Fuzzer

BalenaCloud

Robotiun

Q. Attacker Lauren has gained the credentials of an organization's internal server system, and she was often logging in during irregular times to monitor the network activities. The organization was skeptical about the login times and appointed security professional Robert to determine the issue. Robert analyzed the compromised device to find incident details such as the type of attack, its severity, target, impact, method of propagation, and vulnerabilities exploited.

What is the incident handling and response (IH&R) phase, in which Robert has determined these issues?

Eradication

Incident triage

Preparation

Incident recording and assignment

Q. At what stage of the cyber kill chain theory model does data exfiltration occur?

Weaponization

Command and control

Actions on objectives

Installation

Q. John is investigating web-application firewall logs and observes that someone is attempting to inject the following:

```
char buff[10];
```

```
buff[10] = 'a';
```

What type of attack is this?

CSRF

XSS

SQL injection

Buffer overflow

Q. Jack, a disgruntled ex-employee of Incalsol Ltd., decided to inject fileless malware into Incalsol's systems. To deliver the malware, he used the current employees' email IDs to send fraudulent emails embedded with malicious links that seem to be legitimate. When a victim employee clicks on the link, they are directed to a fraudulent website that automatically loads Flash and triggers the exploit.

What is the technique used by Jack to launch the fileless malware on the target systems?

Phishing

Legitimate applications

In-memory exploits

Script-based injection

Q. You are using a public Wi-Fi network inside a coffee shop. Before surfing the web, you use your VPN, to prevent intruders from sniffing your traffic if you did not have a VPN , how would you identify whether someone is performing ARP spoofing attack on your laptop?

You cannot identify such an attack and must use a VPN to protect your traffic

You should check your ARP table and see if there is one IP address with two different MAC address

You should scan the network using Nmap to check the MAC addresses of all the hosts and look for Duplicates